TECHNICAL DETAIL

Title	Broken Access Control: Unauthorized Access to Transaction & Revenue Dashboard
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com
Date	2025-12-28
Affected Asset	https://bertani.my.id/transactions
Severity	Medium
CVSS Score	5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)
Proof of Concepts	Please see Steps to Reproduce section

SUMMARY

Ditemukan kerentanan kontrol akses (Broken Access Control) pada platform bertani.my.id yang memungkinkan akses publik tanpa autentikasi ke halaman Manajemen Transaksi. Melalui teknik pemindaian direktori, teridentifikasi bahwa endpoint /transactions dapat diakses secara langsung oleh pengguna anonim. Eksploitasi terhadap celah ini mengakibatkan kebocoran data finansial sensitif perusahaan, termasuk statistik total pendapatan bulanan, jumlah transaksi, dan ringkasan operasional lainnya yang seharusnya bersifat rahasia bagi pihak internal.

STEPS TO REPRODUCE

1. jalankan command gobuster dir -u https://bertani.my.id -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -s "200,204,301,302,307,403" -b ""

```
┌──(nectar㉿nectar)-[~]
└─$ gobuster dir -u https://bertani.my.id -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -s "200,204,301,302,307,403" -b ""
===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:            https://bertani.my.id
[+] Method:         GET
[+] Threads:        10
[+] Wordlist:       /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Status codes:   200,204,301,302,307,403
[+] User Agent:     gobuster/3.8
[+] Timeout:        10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/home                 (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
/login                (Status: 200) [Size: 8379]
/register             (Status: 200) [Size: 10742]
/forum                (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
/user                 (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
/video                (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
/users                (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
/shop                 (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
/photo                (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
/storage              (Status: 301) [Size: 178] [--> https://bertani.my.id/storage/]
/css                  (Status: 301) [Size: 178] [--> https://bertani.my.id/css/]
/message              (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
/request              (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
/catalogue            (Status: 200) [Size: 8764]
/knowledge            (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
/transactions         (Status: 200) [Size: 4361]
/prediction           (Status: 302) [Size: 354] [--> https://bertani.my.id/login]
Progress: 220558 / 220558 (100.00%)
===============================================================
Finished
===============================================================
```

2. Dari informasi tersebut kita bisa melihat kita dapat masuk ke url transactions tanpa harus login

3. Tampilan saat masuk ke url https://beratani.my.id/transactions / tanpa harus login

EXPECTED RESULT

Halaman /transactions yang berisi data finansial seharusnya dilindungi oleh *middleware* autentikasi dan otorisasi yang ketat. Pengguna anonim seharusnya diarahkan kembali ke halaman login (Status 302).

ACTUAL RESULT

Aplikasi mengizinkan akses anonim secara penuh ke dasbor transaksi. Siapa pun dapat melihat ringkasan pendapatan perusahaan senilai Rp 2.000.000, jumlah transaksi bulan ini (50), serta statistik stok tanaman (100) tanpa memiliki hak akses yang sah atau melalui proses autentikasi.

IMPACT

1. Information Disclosure (Medium): Kebocoran data finansial dan operasional internal yang dapat dimanfaatkan oleh kompetitor atau pihak luar untuk mengukur kondisi bisnis perusahaan.
2. Privacy Breach: Paparan ringkasan transaksi dan riwayat aktivitas bisnis yang seharusnya terbatas hanya untuk personel internal perusahaan.

RECOMMENDATION

1. Gunakan Middleware Autentikasi: Pastikan rute /transactions dilindungi oleh middleware auth pada aplikasi Laravel untuk mencegah akses tidak sah.
2. Audit Akses Rute: Lakukan pemeriksaan menyeluruh terhadap berkas konfigurasi routing (web.php atau api.php) untuk memastikan tidak ada rute administratif atau manajerial lain yang terbuka untuk publik

REFERENCES

1. OWASP Top 10 - A01:2021 Broken Access Control: https://owasp.org/Top10/A01_2021-Broken_Access_Control/
2. CWE-284: Improper Access Control: https://cwe.mitre.org/data/definitions/284.html